Ethical Hacking Exam Prep: DoS/DDoS

Nov 11, 2026

This guide covers the DoS/DDoS domain of a CEH-style ethical hacking exam: core concepts, attack techniques, botnets, a real-world case study, common tools, countermeasures, protection tools, and two hands-on lab walkthroughs.

> **Lab safety notice:** Every hands-on section (SYN flood with hping3/Metasploit, DDoS simulation with LOIC/HOIC) describes actions for an isolated, authorized lab only — your own VMs on a private virtual network, never a live/production system or anyone else's infrastructure. Running these tools against systems you do not own or lack explicit written authorization for is illegal in most jurisdictions (e.g., under computer-misuse laws such as the CFAA or India's IT Act) and is outside the scope of ethical testing.

1. DoS/DDoS Concepts

A **Denial-of-Service (DoS)** attack floods a single target from one source so it can't serve legitimate users — it attacks the **Availability** leg of the CIA triad rather than confidentiality or integrity. A **Distributed Denial-of-Service (DDoS)** attack does the same thing but from many distributed sources at once (often a botnet), making it harder to block by simply filtering one IP.

Key distinction for the exam: DoS = one attacker, one machine. DDoS = many compromised machines (zombies/bots), coordinated by a handler/C2, attacking one or more targets simultaneously.

Common symptoms of an attack:

- Unusually slow network performance (opening files, accessing websites)
- Unavailability of a particular website
- Inability to access any website
- Dramatic increase in spam email
- Disconnection of a wireless/wired internet connection
- Long-term denial of access to the web or internet services

Why attackers launch DoS/DDoS attacks (motives):

- Financial gain (extortion / ransom DDoS, demanding payment to stop)

- Hacktivism / ideological protest
- Competitive business sabotage
- Revenge or personal grievance
- Cyberwarfare / nation-state disruption
- As a smokescreen/distraction while another attack (data exfiltration, intrusion) happens elsewhere

Business impact: revenue loss from downtime, reputational damage, SLA violations, cost of emergency mitigation, and potential compliance/legal exposure if customer-facing services are affected.

2. DoS/DDoS Attack Techniques

Volumetric attacks (saturate bandwidth):

- **UDP Flood** — sends large numbers of UDP packets to random ports; the host replies with ICMP "destination unreachable", consuming resources.
- **ICMP Flood (Ping Flood)** — overwhelms the target with ICMP Echo Request packets.
- **Ping of Death** — sends malformed/oversized ping packets that can crash older/unpatched systems.
- **Smurf Attack** — spoofs the victim's IP and broadcasts ICMP requests to a network, so all hosts reply to the victim at once (amplification via broadcast).

Protocol attacks (exhaust server/connection-state resources or network equipment):

- **SYN Flood** — sends a flood of TCP SYN packets, often with spoofed source IPs, without completing the three-way handshake, exhausting the target's connection (backlog) table.
- **ACK Flood / Fragmentation Attack** — sends spoofed ACK or fragmented packets that force the target to spend CPU time reassembling or validating them.

Application-layer attacks (target application logic, low bandwidth, hard to detect):

- **HTTP GET/POST Flood** — mimics legitimate HTTP requests at huge volume to exhaust web-server resources.
- **Slowloris** — opens many connections and sends partial HTTP headers very slowly, keeping connections open and exhausting the server's connection pool.
- **Slow POST (R-U-Dead-Yet)** — sends a POST request with a large Content-Length header but trickles the body in very slowly.

Amplification/Reflection attacks (spoof victim's IP, send small requests to third-party servers that generate large responses to the victim):

- DNS amplification, NTP amplification, SNMP amplification, Memcached amplification — all exploit protocols where a small request yields a much larger response, multiplying attack bandwidth.

Other categories:

- **Permanent DoS (Phlashing/Bricking)** — damages a system's firmware/hardware configuration so it requires reinstallation or replacement.
- **Peer-to-Peer attacks** — exploit flaws in P2P file-sharing protocols to redirect clients to flood a victim.
- **Multi-vector attacks** — combine several techniques (e.g., volumetric + application-layer) simultaneously to defeat single-layer defenses.

3. Botnets

A **botnet** is a network of compromised, internet-connected devices ("bots" or "zombies") infected with malware and controlled remotely by an attacker (the **botmaster**) through a **Command-and-Control (C2)** infrastructure, without the device owners' knowledge.

C2 architectures:

- **Centralized (IRC/HTTP-based)** — all bots connect to one or a few central C2 servers; simple but has a single point of failure for defenders to take down.
- **Peer-to-Peer (P2P)** — bots relay commands to each other with no single central server, making the botnet far more resilient to takedown.
- **Decentralized/hybrid** — mixes both models, often using domain generation algorithms (DGAs) to rotate C2 domains and evade blocklists.

Botnet lifecycle:

1. **Infection/Recruitment** — malware spreads via phishing, drive-by downloads, exploiting unpatched vulnerabilities, or (especially for IoT) scanning for default/weak credentials.
2. **Rally** — infected bots "check in" with the C2 to register and await instructions.
3. **Waiting** — bots sit dormant, periodically polling the C2.
4. **Attack** — botmaster issues a command (e.g., launch SYN flood against target X); all bots execute simultaneously.

Known botnet malware (exam-relevant):

- **Mirai** — infected IoT devices (routers, IP cameras, DVRs) via default telnet/SSH credentials; source code leaked in 2016, spawning many variants.
- **Gafgyt/BASHLITE** — another IoT-targeting botnet family, often used for DDoS-for-hire.

Botnet-as-a-Service (booter/stresser services): criminal marketplaces rent out botnet capacity for DDoS attacks, lowering the technical bar for launching large-scale attacks.

4. DDoS Case Study: Mirai Botnet vs. Dyn (October 2016)

This is the most commonly referenced DDoS case study in ethical-hacking curricula.

Detail	Summary
Malware	Mirai
Target	Dyn, a major DNS provider
Date	October 21, 2016
Vector	Massive DNS-request flood from a Mirai-based IoT botnet
Scale	Hundreds of thousands of infected IoT devices (cameras, routers, DVRs) compromised via default/weak telnet credentials
Impact	Dyn's DNS resolution was overwhelmed, making numerous major sites (including large platforms relying on Dyn for DNS) unreachable for users across the US and Europe for several hours

How it worked: Mirai scanned the internet for IoT devices still using factory-default usernames/passwords, logged in via Telnet, and installed bot malware. The botmaster then directed the resulting botnet to flood Dyn's DNS infrastructure with traffic, which indirectly knocked many unrelated websites offline since their DNS resolution depended on Dyn.

Lessons learned (exam-relevant takeaways):

- IoT devices are a major and growing attack surface because they are rarely patched and often ship with weak default credentials.
- DNS is a critical single point of dependency — taking down a shared DNS provider can cascade to many unrelated services.
- Source code for Mirai was later published publicly, leading to many copycat variants.
- Organizations should enforce credential hygiene on IoT devices, use multiple/redundant DNS providers, and deploy DDoS-scrubbing services upstream of critical infrastructure.

5. DoS/DDoS Attack Tools

For the exam you mainly need to recognize these tools and the attack category each one belongs to — not memorize every option.

Tool	Category	Notes
LOIC (Low Orbit Ion Cannon)	Volumetric / application (UDP, TCP, HTTP flood)	GUI tool popularized by Anonymous; simple, single-source unless used by many volunteers at once
HOIC (High Orbit Ion Cannon)	Volumetric / application (HTTP flood)	Successor to LOIC; supports "booster" scripts to multiply threads and hit multiple targets at once
hping3	Protocol (custom TCP/IP packet crafting)	Command-line packet generator; commonly used to craft SYN floods and other packet-based tests
Metasploit (auxiliary/dos/* modules)	Protocol / application	Pentest framework with built-in DoS auxiliary modules (e.g., `auxiliary/dos/tcp/synflood`)
Slowloris	Application layer	Keeps many connections open with partial HTTP headers to exhaust server threads
HULK (HTTP Unbearable Load King)	Application layer	Generates unique, obfuscated HTTP GET requests to bypass caching and overload web servers

Tool	Category	Notes
R-U-Dead-Yet (RUDY)	Application layer	Slow POST-style attack, trickles form data very slowly
Tsunami / Trinoo / TFN2K	Legacy DDoS frameworks	Classic distributed attack tools referenced historically in CEH material

In a real engagement, these tools are used only in a scoped, written-authorized penetration test or in an isolated training lab — never against production systems without explicit permission.

6. Countermeasures

- **SYN cookies** — server encodes connection state into the SYN-ACK sequence number instead of storing it, avoiding backlog-table exhaustion from SYN floods.
- **Rate limiting / connection limiting** — cap the number of requests or connections per source IP in a time window.
- **Ingress/egress filtering** — block spoofed source IPs at network edges (e.g., BCP38) to reduce reflection/amplification abuse.
- **Blackhole / sinkhole routing** — route attack traffic to a null destination (blackhole) or a monitored collection point (sinkhole) to protect the rest of the network.
- **Anycast routing** — distribute incoming traffic across many geographically dispersed servers so no single node absorbs the full attack.
- **Upstream scrubbing centers** — redirect traffic through a provider that filters malicious packets before forwarding clean traffic to the origin.
- **Load balancing** — spread traffic across multiple servers to increase overall capacity and resilience.
- **Web Application Firewall (WAF) / CDN** — absorb and filter application-layer floods close to the edge, cache static content to reduce origin load.
- **Disable unused services/ports** and keep systems patched to reduce the attack surface (e.g., against protocol-level exploits like Ping of Death).
- **Capacity planning / auto-scaling** — provision headroom and elastic scaling so moderate volumetric spikes don't cause outages.
- **Incident response plan** — predefined runbook: detection thresholds, escalation contacts, ISP/CDN coordination, and post-incident review.

7. DoS/DDoS Protection Tools

Tool/Service	Type	Notes
Cloudflare	Cloud CDN + DDoS protection	Edge network absorbs volumetric and application-layer attacks before they reach origin
AWS Shield (Standard/Advanced)	Cloud DDoS protection	Native protection for AWS-hosted resources, integrates with WAF and Route 53
Akamai Kona / Prolexic	Cloud scrubbing	Enterprise-grade scrubbing centers for very large volumetric attacks
Imperva	WAF / DDoS mitigation	Application and network-layer protection
Arbor Networks / NETSCOUT	On-prem + cloud hybrid	Widely used for ISP/enterprise traffic visibility and mitigation
F5 Silverline	Cloud-based mitigation	Scrubbing service integrated with F5 application delivery products
fail2ban	Open source, host-level	Bans IPs showing malicious patterns in logs (e.g., repeated failed logins, flood patterns)
iptables / nftables rate limiting	Open source, host/network-level	`-m limit` module throttles packet rates per rule
mod_evasive (Apache module)	Open source, web-server level	Detects and blocks HTTP flood patterns against Apache
Snort / Suricata	Open source IDS/IPS	Signature and anomaly-based detection of flood/attack patterns

8. Lab: SYN Flooding with hping3 and Metasploit

> **Run this only on your own isolated lab network** — an attacker VM (e.g., Kali Linux) and a target VM you own, both on a private/host-only virtual network with no route to the internet or any production system.

A. SYN flood with hping3

hping3 is a command-line packet-crafting tool. A basic SYN flood:

```
hping3 -S --flood -V -p 80 <target-IP>
```

- `-S` — set the SYN flag (initiate a TCP handshake without completing it)
- `--flood` — send packets as fast as possible, don't wait for replies (this also suppresses reply display)
- `-V` — verbose output
- `-p 80` — target port (change to whatever service you are testing)
- `-a <spoofed-IP>` (optional) — spoof the source address so replies don't return to your own host and backscatter is simulated; only meaningful in a lab where you control routing

B. SYN flood with Metasploit

```
msfconsole
use auxiliary/dos/tcp/synflood
show options
set RHOST <target-IP>
set RPORT 80
set SHOST <spoofed-source-IP>   # optional, simulate spoofing
run
```

- `RHOST` / `RPORT` — the target IP and port
- `SHOST` — source IP Metasploit will spoof in the crafted SYN packets (optional)
- `run` — launches the flood; stop with Ctrl+C or `exploit` session controls

C. Observing the effect on the target

On the target VM, run:

```
netstat -an | grep SYN_RECV | wc -l
```

A healthy system shows a small, stable number of `SYN_RECV` entries. Under a SYN flood you'll see this count climb toward the connection backlog limit, and new legitimate connections start timing out — this is the exhaustion of the TCP backlog queue that defines a SYN flood's impact.

D. Cleanup

Stop the flood tool, confirm `SYN_RECV` count returns to baseline, and document observed metrics (CPU, memory, connection counts) for your lab report.

9. Lab: DDoS Simulation with LOIC and HOIC

> **Legal warning:** LOIC and HOIC were historically used by hacktivist groups (notably Anonymous) in real, unauthorized attacks that led to criminal prosecutions. Using them against anything you don't own, or without explicit written authorization, is a serious crime in most countries. The steps below are for a closed lab exercise only — attacker VM and target VM on an isolated private network you control.

What they are:

- **LOIC (Low Orbit Ion Cannon)** — an open-source stress-testing tool that floods a target with TCP, UDP, or HTTP requests from a simple GUI. Originally built for network stress testing, it became widely known as a DIY DDoS tool because many volunteers running it against the same target created a crude distributed attack (a "voluntary botnet").
- **HOIC (High Orbit Ion Cannon)** — a successor to LOIC that adds multi-threading and "booster scripts" (small text macros) allowing a single instance to target multiple URLs with randomized HTTP headers, making the traffic harder to filter and the tool more powerful per attacker.

Generic lab walkthrough:

1. Set up an isolated lab network with an attacker VM (where LOIC/HOIC runs, typically on Windows) and a target VM you own (e.g., a simple web server) — no bridge to the internet.
2. Launch the tool and enter the target's IP address or URL in the designated field.
3. Select the attack method (TCP, UDP, or HTTP in LOIC; HTTP with boosters in HOIC).

4. Set the port and thread count (number of simultaneous connections).
5. Click the "fire"/start button to begin sending traffic.
6. On the target VM, monitor resource usage (CPU, memory, active connections via `netstat` or Task Manager/ `top`) to observe degradation and correlate it with the technique categories from Section 2.
7. Stop the attack and confirm the target returns to baseline performance; record findings for your lab report.

Exam angle: know that LOIC/HOIC are associated with hacktivism (Anonymous), that LOIC alone is a single-source tool (true distribution requires many volunteers), and that HOIC's booster scripts are its distinguishing exam-relevant feature over LOIC.

10. Detect and Protect Against DDoS Attacks

Detection methods:

- **Traffic baselining / anomaly detection** — establish normal traffic patterns (volume, protocol mix, geography) and alert on statistically significant deviations.
- **Connection-state monitoring** — track `SYN_RECV` counts, half-open connections, and connections-per-source-IP for signs of a protocol-level flood.
- **Flow analysis (NetFlow/sFlow/IPFIX)** — analyze aggregated traffic flows at the router/switch level to spot volumetric spikes without full packet capture.
- **IDS/IPS signatures** — Snort/Suricata rules matching known flood signatures (e.g., repeated SYN without ACK, malformed packets).
- **Log analysis** — web server and firewall logs reveal patterns like a surge of requests from a narrow IP range or unusual User-Agent strings.

Layered protection strategy (defense in depth):

1. **Edge/cloud layer** — CDN + cloud scrubbing (Cloudflare, AWS Shield, Akamai) absorbs most volumetric and application-layer traffic before it reaches your origin.
2. **Network layer** — rate limiting, SYN cookies, ingress/egress filtering (BCP38), blackhole/sinkhole routing for confirmed attack sources.
3. **Application layer** — WAF rules, CAPTCHA challenges for suspicious clients, connection timeouts tuned against Slowloris-style attacks.
4. **Infrastructure resilience** — anycast DNS, geographically distributed/redundant servers, auto-scaling to absorb legitimate traffic surges.

5. **Process** — a written incident response runbook: detection thresholds and alerting, an on-call escalation path, pre-established contact with your ISP/CDN provider for emergency mitigation, and a post-incident review to update defenses.

Exam tip: no single control stops every DDoS type — SYN cookies defend against protocol attacks but do nothing for a Slowloris-style application attack, so the correct exam answer is usually "defense in depth across multiple layers," not one silver-bullet tool.

Quick Exam-Revision Checklist

- DoS = one source; DDoS = many distributed sources (botnet).
- SYN flood exploits the TCP three-way handshake by never completing it, filling the backlog/ `SYN_RECV` queue.
- Smurf attack = spoofed ICMP + network broadcast amplification.
- Slowloris / Slow POST (RUDY) = application-layer attacks that hold connections open rather than flood bandwidth.
- DNS, NTP, SNMP, Memcached = classic amplification/reflection protocols (small request → huge response, spoofed victim IP).
- Mirai = IoT botnet malware behind the 2016 Dyn DNS attack; spread via default telnet credentials.
- LOIC = single-tool flood (needs many volunteers for true DDoS); HOIC adds booster scripts + multi-threading.
- SYN cookies = stateless defense against SYN floods (no backlog table needed).
- Anycast + CDN + scrubbing centers = core infrastructure-level DDoS mitigations.
- No single countermeasure stops all DDoS types — exam answers favor layered/defense-in-depth strategies.
- Permanent DoS (phlashing) damages firmware/hardware, unlike transient floods.
- Always tie any "perform an attack" exam scenario to an authorized/isolated lab context — unauthorized use is illegal.